

README – Kit de Encuesta de Madurez CMMC / NIS2 / ENS

Bienvenido/a al kit de autoexamen razonablemente honesto de tu madurez de ciberseguridad.

1. Contenido del kit

El kit está formado por los siguientes archivos (todos en formato Markdown, listos para versionar en Git o similar):

- (a) encuesta_cmmc_integral.md – Modelo completo de encuesta para responsables de seguridad.
- (b) guía_metodologica_cmmc.md – Guía metodológica: objetivos, diseño, puntuación, índices.
- (c) narrativa_explicativa_cmmc.md – Narrativa para explicar el “por qué” y el “para qué” de la encuesta.
- (d) mapeo_preguntas_normativa_cmmc.md – Tabla de mapeo de cada pregunta a CMMC, NIST, ENS, NIS2, etc.
- (e) plantilla_excel_igm_roi.md – Instrucciones para crear la hoja de cálculo de IGM y ROI.
- (f) plantilla_reporte_ejecutivo_ppt.md – Esqueleto de presentación ejecutiva en PowerPoint.
- (g) README_kit_encuesta_cmmc.md – Este mismo documento.

2. Uso recomendado (en 5 pasos)

1. Adaptación ligera
2. Revisar el cuestionario (a) y ajustar el tono, ejemplos y cierta terminología a tu sector (sanidad, industria, administración, etc.).
3.
Mantener, en la medida de lo posible, la estructura de bloques y escalas de respuesta.
4.
Configuración de la herramienta de recogida
5. Volcar las preguntas en la plataforma de encuestas que se vaya a utilizar (online o interna).
6.
Asegurarse de que cada pregunta tenga un identificador (Q1_1, Q3_2, etc.) para el posterior análisis en Excel.
7.
Aplicación de la encuesta
8. Definir a quién se enviará (CISO, IT, riesgo, cumplimiento, etc.).
9. Comunicar el propósito: diagnóstico y mejora, no caza de brujas.
10.
Establecer un plazo y enviar recordatorios sensatos.
11.
Análisis de resultados
12.
Usar la plantilla Excel descrita en (e) para calcular:

Puntuación por pregunta y bloque.
Índice Global de Madurez (IGM).
Índices parciales (IGC, ITEC, IRES, ICAS).
Indicadores de ROI cuando se disponga de datos económicos.
13.
Comunicación y acción
14. Construir el reporte ejecutivo siguiendo la plantilla (f).
15. Presentar resultados a la dirección y acordar una hoja de ruta de mejora.
16. Establecer una frecuencia de repetición (por ejemplo, anual) para medir evolución.

Mantener, en la medida de lo posible, la estructura de bloques y escalas de respuesta.

Configuración de la herramienta de recogida

Asegurarse de que cada pregunta tenga un identificador (Q1_1, Q3_2, etc.) para el posterior análisis en Excel.

Aplicación de la encuesta

Establecer un plazo y enviar recordatorios sensatos.

Análisis de resultados

Usar la plantilla Excel descrita en (e) para calcular:

- Puntuación por pregunta y bloque.
- Índice Global de Madurez (IGM).
- Índices parciales (IGC, ITEC, IRES, ICAS).
- Indicadores de ROI cuando se disponga de datos económicos.

Comunicación y acción

3. Adaptación por sector

El kit está diseñado para ser **sector-agnóstico**, pero:

- En sanidad, se pueden reforzar aspectos de protección de datos sensibles (historias clínicas) y continuidad asistencial.
- En industria y exportación, conviene enfatizar cadena de suministro, OT/ICS y requisitos de clientes internacionales (incluyendo DoD/CMMC cuando aplique).
- En administración pública, el ENS y las obligaciones de NIS2 deben tener un papel central en el mapeo y en las prioridades.

Nada impide crear variantes sectoriales del cuestionario y de los pesos de bloques en el cálculo del IGM.

4. Buenas prácticas de implantación

- Transparencia: explicar claramente cómo se usarán los datos y quién tendrá acceso.
- Confidencialidad: anonimizar resultados en reportes agregados, salvo acuerdo expreso.
- Iteración: empezar con una versión 1.0 y mejorar el cuestionario a la vista de la experiencia.
- Triangulación: complementar la encuesta con evidencias, métricas reales e incidentes históricos.

5. Límites y precauciones

- Es una herramienta de autoevaluación estructurada, no un dictamen de organismo regulador.
- Los índices sintetizan mucha información: útiles para ilustrar, peligrosos para simplificar en exceso.
- Es fácil obsesionarse con el número (IGM) y olvidar el relato: ambos son necesarios.

6. Próximos pasos sugeridos

- Definir un piloto en una o dos unidades/organizaciones antes de desplegarlo masivamente.
- Afinar pesos y escalas a partir de esa primera experiencia.
- Considerar el uso del kit como base para:
 - Programas sectoriales de madurez.
 - Iniciativas de certificación voluntaria.
- Herramientas de diálogo con aseguradoras y grandes clientes.

Si llegas a utilizar este kit para mejorar la postura de seguridad de tu organización (y de paso, la del país), considérate oficialmente culpable de una buena influencia.